

ORTHRUS SECURITY REPORT

Scan Date

2026-05-30 18:42:49

Target

<https://petstore3.swagger.io/api/v3/openapi.json>

Legal & Confidentiality Disclaimer

This report is STRICTLY CONFIDENTIAL and its distribution is subject to restriction. It is intended solely for authorized personnel. It is generated by an automated security testing tool (Orthrus). The tool assigns a theoretical Base CVSS score which may not reflect the environmental or temporal context of the vulnerability. The authors and the tool itself are not liable for any missed vulnerabilities, critical flaws that were not detected, or subsequent compromises of the tested systems. This tool is provided for authorized security testing only.

Methodology & Scoring Criteria

This report presents the findings of an automated Dynamic Application Security Testing (DAST) scan. The scan involved sending various malicious payloads and unexpected inputs to the target API to identify security vulnerabilities.

Orthrus utilizes an advanced taxonomy to categorize findings.

- **CVSS 3.1 Base Score:** Provides a theoretical numerical score (0.0 to 10.0) reflecting the intrinsic qualities of a vulnerability.
- **CAPEC:** Common Attack Pattern Enumeration and Classification, identifying the specific attack mechanisms used.
- **OWASP:** Maps the findings to the latest API Security Top 10 guidelines.
- **Global Grade:** A letter grade (A to F) assessing the overall security posture based on the highest severity vulnerabilities found.

Global Summary

Security Grade

F

Total Vulnerabilities	CRITICAL	HIGH	MEDIUM	LOW	INFO
99	2	6	14	77	0

Detailed Findings

1. OS Command Injection

[CRITICAL]

OWASP Category: Injection | Confidence: HIGH

Base CVSS Score: 9.8

78

CAPEC-88

CWE

CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')

Endpoint

GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The endpoint executes user-supplied commands on the underlying operating system.

Remediation

Avoid executing OS commands directly. If necessary, use safe lower-level APIs and strictly validate input using an allowlist.

Evidence

Response contains the injected marker string 'VULNAPI_CMD_INJECT_SUCCESS', indicating the OS command was executed and its output was returned.

2. Server-Side Template Injection (SSTI)

[CRITICAL]

OWASP Category: Injection | Confidence: HIGH

Base CVSS Score: 9.8

1336

CAPEC-137

CWE

CWE-1336: Improper Neutralization of Special Elements Used in a Template Engine

Endpoint

GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The endpoint evaluates user input as template code, allowing arbitrary code execution on the server.

Remediation

Never evaluate user input directly as template code. Use logicless templates or execute templates in a secure sandbox.

Evidence

Response contains the evaluated result ('49') of the injected template expression '{{7*7}}'.

3. Potential SQL Injection

[HIGH]

OWASP Category: Injection | **Confidence:** MEDIUM

Base CVSS Score: 9.8

89

CAPEC-66

CWE

CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')

Endpoint

GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The endpoint might be vulnerable to SQL Injection.

Remediation

Use parameterized queries (Prepared Statements) or ORMs. Never directly interpolate user input into SQL queries.

Evidence

Response indicates a database error when payload `' ' OR '1'='1'` was injected.

4. Potential NoSQL Injection

[HIGH]

OWASP Category: Injection | **Confidence:** MEDIUM

Base CVSS Score: 9.8

943

CAPEC-66

CWE

CWE-943: Improper Neutralization of Special Elements in Data Query Logic

Endpoint

GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The endpoint might be vulnerable to NoSQL Injection (e.g., MongoDB).

Remediation

Do not insert user data directly into database queries. Use secure querying features provided by your NoSQL client.

Evidence

Response indicates a NoSQL database error when payload `'{"$ne": null}'` was injected.

5. Potential NoSQL Injection

[HIGH]

OWASP Category: Injection | **Confidence:** MEDIUM

Base CVSS Score: 9.8

943

CAPEC-66

CWE

CWE-943: Improper Neutralization of Special Elements in Data Query Logic

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

The endpoint might be vulnerable to NoSQL Injection (e.g., MongoDB).

Remediation

Do not insert user data directly into database queries. Use secure querying features provided by your NoSQL client.

Evidence

Response indicates a NoSQL database error when payload `'{"$ne": null}'` was injected.

6. Potential SQL Injection

[HIGH]

OWASP Category: Injection | **Confidence:** MEDIUM

Base CVSS Score: 9.8

89

CAPEC-66

CWE

CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

The endpoint might be vulnerable to SQL Injection.

Remediation

Use parameterized queries (Prepared Statements) or ORMs. Never directly interpolate user input into SQL queries.

Evidence

Response indicates a database error when payload `' ' OR '1'='1'` was injected.

7. Potential NoSQL Injection

[HIGH]

OWASP Category: Injection | **Confidence:** MEDIUM

Base CVSS Score: 9.8

943

CAPEC-66

CWE

CWE-943: Improper Neutralization of Special Elements in Data Query Logic

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

The endpoint might be vulnerable to NoSQL Injection (e.g., MongoDB).

Remediation

Do not insert user data directly into database queries. Use secure querying features provided by your NoSQL client.

Evidence

Response indicates a NoSQL database error when payload `'{"$ne": null}'` was injected.

8. Potential SQL Injection

[HIGH]

OWASP Category: Injection | **Confidence:** MEDIUM

Base CVSS Score: 9.8

89

CAPEC-66

CWE

CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

The endpoint might be vulnerable to SQL Injection.

Remediation

Use parameterized queries (Prepared Statements) or ORMs. Never directly interpolate user input into SQL queries.

Evidence

Response indicates a database error when payload `' ' OR '1'='1'` was injected.

9. Reflected Cross-Site Scripting (XSS)

[MEDIUM]

OWASP Category: Injection | **Confidence:** HIGH

Base CVSS Score: 6.1

79

CAPEC-63

CWE

CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

Endpoint

GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The endpoint reflects unencoded user input into the response.

Remediation

Always encode user-supplied data before rendering it in the response. Use your framework's native escaping mechanisms.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

10. Potential Broken Object Level Authorization (BOLA)

[MEDIUM]

OWASP Category: Broken Object Level Authorization | **Confidence:** LOW

Base CVSS Score: 7.5

639

CAPEC-17

CWE

CWE-639: Authorization Bypass Through User-Controlled Key

Endpoint

GET <https://petstore3.swagger.io/api/v3/store/order/42>

Description

User A could access data belonging to User B by manipulating object identifiers in the request.

Remediation

Verify that the authenticated user actually has the authorization to access the requested resource, and do not rely solely on the provided ID.

Evidence

Response status 200 OK when accessing ID 42

11. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 500 instead of 429.

12. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 500 instead of 429.

13. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/pet/28>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 500 instead of 429.

14. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 500 instead of 429.

15. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/23/uploadImage>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 400 instead of 429.

16. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

POST <https://petstore3.swagger.io/api/v3/store/order>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 500 instead of 429.

17. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/store/order/66>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 500 instead of 429.

18. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

POST <https://petstore3.swagger.io/api/v3/user>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 500 instead of 429.

19. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 200 instead of 429.

20. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

POST <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 400 instead of 429.

21. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

PUT <https://petstore3.swagger.io/api/v3/user/dignissimos>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 500 instead of 429.

22. Missing Rate Limiting

[MEDIUM]

OWASP Category: Lack of Resources & Rate Limiting | **Confidence:** LOW

Base CVSS Score: 5.3

799

CAPEC-115

CWE

CWE-799: Improper Control of Interaction Frequency

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/user/officiis>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Evidence

After 30 requests, the server returned status 500 instead of 429.

23. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/findByStatus

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

24. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/findByStatus

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

25. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/findByStatus

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

26. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/findByStatus

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

27. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

28. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

29. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

30. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

31. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/findByTags

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

32. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/findByTags

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

33. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

34. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

35. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/42

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

36. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/42

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

37. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/42

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

38. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/pet/42

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

39. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

40. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

41. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

42. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

43. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

PUT <https://petstore3.swagger.io/api/v3/pet>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

44. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

PUT <https://petstore3.swagger.io/api/v3/pet>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

45. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

46. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

PUT <https://petstore3.swagger.io/api/v3/pet>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

47. Unhandled Exception on Unexpected Content-Type

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 7.5

209

CAPEC-228

CWE

CWE-209: Generation of Error Message Containing Sensitive Information

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/14>

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Remediation

Catch server-side exceptions and return generic error messages to the user. Never leak stack traces in production environments.

Evidence

```
Server returned 7.5 Internal Server Error when receiving application/xml.
```

48. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/23/uploadImage>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

```
Header 'Strict-Transport-Security' is missing from the response.
```

49. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/23/uploadImage>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

50. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/23/uploadImage>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

51. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/pet/23/uploadImage>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

52. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/pet/28>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

53. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/pet/28>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

54. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/pet/28>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

55. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/pet/28>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

56. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET <https://petstore3.swagger.io/api/v3/store/inventory>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

57. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/store/inventory

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

58. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

GET https://petstore3.swagger.io/api/v3/store/inventory

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

59. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET <https://petstore3.swagger.io/api/v3/store/inventory>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

60. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/store/order>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

61. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/store/order>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

62. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

POST <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

63. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/store/order>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

64. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET <https://petstore3.swagger.io/api/v3/store/order/41>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

65. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/store/order/41

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

66. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

GET https://petstore3.swagger.io/api/v3/store/order/41

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

67. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET <https://petstore3.swagger.io/api/v3/store/order/41>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

68. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/store/order/66>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

69. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/store/order/66>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

70. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/store/order/66>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

71. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/store/order/66>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

72. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

73. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/user>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

74. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/user>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

75. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

POST <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

76. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/user>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

77. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST https://petstore3.swagger.io/api/v3/user/createWithList

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

78. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

POST https://petstore3.swagger.io/api/v3/user/createWithList

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

79. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

POST <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

80. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET <https://petstore3.swagger.io/api/v3/user/login>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

81. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/user/login

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

82. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

GET https://petstore3.swagger.io/api/v3/user/login

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

83. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/user/login

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

84. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/user/logout

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

85. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/user/logout

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

86. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

GET https://petstore3.swagger.io/api/v3/user/logout

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

87. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/user/logout

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

88. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/user/maiores

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

89. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET https://petstore3.swagger.io/api/v3/user/maiores

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

90. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

GET https://petstore3.swagger.io/api/v3/user/maiores

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

91. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

GET <https://petstore3.swagger.io/api/v3/user/maiores>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

92. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

PUT <https://petstore3.swagger.io/api/v3/user/dignissimos>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

93. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

PUT <https://petstore3.swagger.io/api/v3/user/dignissimos>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

94. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

PUT <https://petstore3.swagger.io/api/v3/user/dignissimos>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

95. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

PUT <https://petstore3.swagger.io/api/v3/user/dignissimos>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.

96. Missing Security Header: HSTS

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/user/officiis>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Strict-Transport-Security' is missing from the response.

97. Missing Security Header: X-Content-Type-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/user/officiis>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'X-Content-Type-Options' is missing from the response.

98. Missing Security Header: X-Frame-Options

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

1021

CAPEC-310

CWE

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/user/officiis>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Evidence

Header 'X-Frame-Options' is missing from the response.

99. Missing Security Header: CSP

[LOW]

OWASP Category: Security Misconfiguration | **Confidence:** HIGH

Base CVSS Score: 4.3

693

CAPEC-310

CWE

CWE-693: Protection Mechanism Failure

Endpoint

DELETE <https://petstore3.swagger.io/api/v3/user/officiis>

Description

A recommended HTTP security header is missing from the response.

Remediation

Configure appropriate HTTP security headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

Evidence

Header 'Content-Security-Policy' is missing from the response.